UNIVERSIDAD DE LAS FUERZAS ARMADAS 'ESPE'

Departamento de Ciencias de la Computación

Ingeniería en tecnologías de la información

A.M. de Sistemas NRC-29293

ACTIVIDAD 4

Integrantes:

Christopher Joel Armas Piarpuezan

Daniel Alexis Quilca Andrade

Isaac Sebastian Proaño Panchi

Camila Nicole Shiguango Valverde

DOCENTE:

Ing. Hernán Jácome

1. Esquema básico de un Plan de Recuperación de Desastres aplicando ISO 22301

1.1 Contexto organizacional (ISO 22301)

La empresa OREO, perteneciente al grupo Mondelēz International, opera con un entorno altamente automatizado y digitalizado. Sus procesos dependen directamente de plataformas tecnológicas tanto de Tecnologías de la Información (TI) como de Tecnología Operativa (OT), lo cual hace indispensable mantener la continuidad de servicios ante fallas o eventos críticos.

El DRP tiene como finalidad garantizar que, tras un incidente, los servicios tecnológicos puedan ser restaurados en tiempos aceptables para evitar pérdidas operativas, económicas, reputacionales o legales.

1.2 Escenario de riesgo definido

Escenario crítico principal: Un ataque de tipo ransomware afecta simultáneamente los sistemas corporativos y parte del entorno OT debido a una propagación desde la red administrativa hacia los sistemas industriales, provocando: caída del ERP SAP; pérdida de acceso a módulos de trazabilidad; interrupción parcial de SCADA y estaciones de ingeniería; e indisponibilidad temporal de herramientas de comunicación.

Impacto directo: detención de producción, bloqueo de despacho, pérdida de trazabilidad alimentaria y posible incumplimiento normativo.

1.3 Procesos críticos de la infraestructura TI/OT

A partir del enfoque de ISO 22301, se priorizan los servicios esenciales para sostener las operaciones del negocio. Para OREO se identifican como críticos:
A) Producción automatizada (OT): SCADA/PLCs/HMI.
B) Gestión de materias primas y trazabilidad (TI + OT): SAP S/4HANA e integración de datos industriales.
C) Logística, distribución y ventas (TI): módulos de despacho, facturación y cumplimiento.
D) Conectividad y comunicaciones: red LAN/WAN y soporte de coordinación.

1.4 Análisis de riesgos y vulnerabilidades

ISO 22301 exige evaluar amenazas y debilidades para determinar prioridades del plan. Entre los riesgos relevantes se incluyen: ransomware por falta de segmentación; fallos eléctricos prolongados; daño físico por incendio o inundación; errores humanos por cambios no controlados; dependencia de un único proveedor cloud; e intrusión física por controles insuficientes.

Las consecuencias potenciales abarcan paralización operativa, pérdida de datos, interrupciones prolongadas y exposición reputacional y legal.

1.5 BIA – Análisis de Impacto en el Negocio

El BIA permite medir qué tan grave es la interrupción de cada proceso y establecer límites máximos de tolerancia. Se evaluaron producción automatizada, inventario y trazabilidad, logística y distribución, y comunicación interna.

Impactos principales: (1) Operativos: detención de líneas y pérdida de control industrial; (2) Económicos: pérdida de producción y costos de restauración; (3) Legales/sanitarios: pérdida de trazabilidad y sanciones; (4) Reputacionales: pérdida de confianza de distribuidores y consumidores.

1.6 Objetivos de recuperación (RTO y RPO)

Con base en el BIA se establecen objetivos de recuperación:
- PLCs/SCADA (OT): RTO < 1 hora; RPO 0 min.
- Red LAN/WAN: RTO 1 hora.
- SAP S/4HANA: RTO 4 horas; RPO 15 min.
- MES / integración planta: RTO 2 horas; RPO 1 hora.
- Correo/colaboración: RTO 24 horas; RPO Correo/Colaboración: < 1 hora. Basado en la retención nativa del proveedor de servicios en la nube.

Estos valores prioriza primero la operación industrial, luego conectividad y finalmente servicios administrativos.

1.7 Estrategias y procedimientos de respuesta

Estrategias recomendadas:
1) Redundancia local OT (alta disponibilidad): PLCs en hot standby y failover.
2) Recuperación cloud para SAP (warm standby): replicación a región alterna y escalamiento.
3) Backups inmutables y segmentación IT/OT: reduce propagación y protege restauración.

Procedimiento de activación del DRP:
1. Detección y registro del incidente.
2. Contención (aislamiento de redes afectadas).
3. Evaluación del impacto.
4. Activación del DRP por autoridad.
5. Recuperación por prioridad (OT → red → SAP → logística).

6. Validación de operación.
7. Retorno controlado a normalidad.
8. Informe y lecciones aprendidas.

1.8 Roles, responsabilidades y comunicación

Roles clave:
- Comité de Continuidad: autoriza activación del DRP y decisiones estratégicas.
- Coordinador de DRP: lidera el plan y coordina equipos.
- Equipo TI: recuperación de SAP, redes, servidores y respaldos.
- Equipo OT: recuperación SCADA/PLCs y control industrial.
- Seguridad de la Información: análisis, contención y evidencia.
- Comunicaciones: mensajes internos/externos y coordinación.
- Proveedores: soporte según SLA.

Protocolo de comunicación:
Canales primarios (Teams/correo/VoIP) y alternos (teléfono/móvil). Comunicación externa solo por áreas autorizadas para evitar desinformación.

1.9 Revisión, pruebas y mejora continua

ISO 22301 establece que el DRP debe mantenerse actualizado mediante revisiones periódicas, control de versiones, actualización de contactos y evaluación de SLA con proveedores.

Pruebas y simulacros propuestos:
- Ejercicios de escritorio (cada 6 meses).
- Pruebas parciales (anual): restauración de backups y módulos.
-Simulacro de escala completa: Anual. Evaluación del desempeño bajo estrés y conmutación real a región de contingencia

Después de cada prueba o incidente se elaborará un informe técnico, se registrarán fallas, se aplicarán correcciones al DRP y se reforzará la capacitación.

Conclusión

El DRP diseñado bajo ISO 22301 permite que OREO asegure la continuidad de sus servicios tecnológicos críticos, minimizando impactos operativos, económicos y reputacionales. La integración del BIA con objetivos de recuperación (RTO/RPO), la asignación clara de roles y una estrategia de mejora continua basada en pruebas y simulacros fortalece la resiliencia organizacional y garantiza la continuidad del negocio ante situaciones de crisis.

2. Analizar y aplicar la metodología del NIST SP 800-34 mediante el diseño de un Plan de Recuperación de Desastres orientado a sistemas de TI de una organización real. Asumir el rol de un comité de contingencia encargado de iniciar el proceso de planificación, definiendo el alcance del plan y los recursos necesarios. Posteriormente, deberán identificar los sistemas y procesos críticos, realizar un Análisis de Impacto en el Negocio (BIA), y evaluar las consecuencias técnicas, operativas y económicas de una interrupción prolongada. Con base en este análisis, proponer estrategias de recuperación viables, documentar procedimientos detallados para restaurar los sistemas críticos y definirán roles y responsabilidades durante un incidente. Finalmente, deberán plantear un esquema de pruebas simuladas y mantenimiento del plan, reflexionando sobre la importancia de la actualización continua y la validación periódica del plan de recuperación, conforme a las buenas prácticas establecidas por el NIST SP 800-34 para garantizar la resiliencia y disponibilidad de los servicios de TI.

Como miembros del comité de contingencia de la organización (fabricante de Oreo), asumimos la responsabilidad de diseñar el Plan de Recuperación de Desastres (DRP) siguiendo la metodología de la norma NIST SP 800-34 para garantizar la resiliencia de sus operaciones altamente automatizadas

El Plan de Recuperación ante Desastres (DRP) para la infraestructura de TI y Tecnología Operativa (OT) que soporta la producción de galletas Oreo en sus plantas automatizadas,siguiendo las directrices del NIST SP 800-34.

2.1 Definición del Comité de Contingencia

Se ha conformado un Comité de Dirección multidisciplinario encargado de la alineación estratégica y asignación de recursos

Rol	**Responsabilidad**
CIO / CTO	Liderazgo y dirección técnica: alinea el

	DRP con los objetivos del negocio.
CEO / COO	Provee autoridad de decisión y asegura que las iniciativas apoyen la estrategia global.
CFO	Prioriza inversiones de recuperación basadas en el análisis de Retorno de Inversión (ROI).
Líderes de Unidades de Negocio	Aportan conocimientos sobre las funciones críticas de producción y ventas.
Oficial de Gestión de Riesgos	Identifica amenazas y vulnerabilidades para priorizar los esfuerzos de recuperación.

2.2 Alcance del Plan

El propósito fundamental es establecer, documentar y operacionalizar los procedimientos necesarios para recuperar las capacidades de misión crítica de la producción de Oreo tras una interrupción del servicio. El alcance abarca la totalidad del ecosistema tecnológico que permite la transformación de materias primas en el producto final empaquetado y entregado. Esto incluye la infraestructura de TI empresarial alojada en la nube (SAP RISE en AWS), los sistemas de control industrial en el piso de fábrica (Rockwell Automation SCADA/PLC), y las redes de comunicación que los unen.

2.3 Recursos Necesarios

El NIST SP 800-34 enfatiza que una planificación efectiva comienza con el establecimiento de una autoridad clara y la asignación adecuada de recursos. Sin un mandato ejecutivo, los esfuerzos de recuperación suelen fragmentarse durante una emergencia real.

2.3.1 Declaración de Política de Planificación de Contingencia

El Comité de Contingencia ha redactado la siguiente política, ratificada por la alta dirección de Mondelēz International, para regir todas las actividades de recuperación de desastres relacionadas con la marca Oreo:

"Es política de Mondelēz International mantener una capacidad integral de recuperación de desastres para todos los sistemas de información que soportan la producción, distribución y venta de productos Oreo. Reconociendo que la información y la infraestructura tecnológica son activos estratégicos vitales, la organización se compromete a implementar el marco de gestión de contingencias descrito en NIST SP 800-34 Rev. 1. Cada sistema clasificado como de impacto moderado o alto según FIPS 199 deberá contar con un Plan de Contingencia de Sistemas de Información (ISCP) actualizado, probado y financiado. La protección de la seguridad humana será siempre la prioridad suprema en cualquier respuesta a incidentes, seguida inmediatamente por la preservación de la integridad de los datos y la restauración de las operaciones de misión crítica. El incumplimiento de los protocolos de mantenimiento y prueba de este plan será considerado una violación de la política de gestión de riesgos corporativos."

Esta política establece la autoridad necesaria para que el Coordinador de Contingencia tome decisiones unilaterales durante una crisis, como la desconexión de redes globales o la activación de sitios de recuperación costosos, sin necesidad de burocracia excesiva que retrase la respuesta.

2.3 Identificación de Recursos Necesarios

Infraestructura de Nube (AWS)	Presupuesto reservado para la activación de instancias "dormidas" o de baja capacidad en la región de recuperación (DR Region). Esto incluye costos de transferencia de datos inter-región y almacenamiento de snapshots inmutables (S3 Object Lock) para protección contra ransomware.
Soporte de Proveedores	Contratos de soporte activo con SAP (MaxAttention o similar) y Rockwell Automation (TechConnect) que garanticen tiempos de respuesta de ingeniería inferiores a 4 horas en situaciones de crisis
Hardware de Repuesto Crítico	Inventario físico en planta de componentes de control (CPUs de PLC ControlLogix, tarjetas de red EtherNet/IP, variadores PowerFlex) que tienen largos tiempos de entrega y son susceptibles a daños por sobretensiones o ataques físicos.
Herramientas de Comunicación Fuera de Banda	Sistemas de comunicación satelital o celular independientes de la red

	corporativa para asegurar la coordinación si la VoIP y el correo electrónico se ven comprometidos como ocurrió durante NotPetya cuando las comunicaciones internas colapsaron

3. Análisis de Impacto en el Negocio (BIA)

El Análisis de Impacto en el Negocio (BIA) constituye el núcleo analítico de la metodología NIST SP 800-34 porque correlaciona los sistemas de TI/OT con los procesos de negocio críticos que soportan, y cuantificar las consecuencias de una interrupción en el tiempo. Esto permite priorizar la recuperación ya que todos los sistemas no son iguales, y en una crisis, los recursos limitados deben dirigirse primero a lo que mantiene viva a la empresa

3.1 Identificación de Procesos Críticos de la Misión Oreo

La producción de una galleta Oreo es una ruta de procesos interdependientes. Una falla en cualquiera de estos y detiene la cadena completa. Hemos identificado tres macro-procesos de misión crítica

3.1.1 Gestión de Materias Primas y Formulación

La recepción de cacao, harina, azúcar y aceite requiere validación de calidad y registro en inventario.

- Sistemas: SAP S/4HANA (Módulo MM/QM) para trazabilidad y liberación de lotes: Rockwell FactoryTalk Batch para la gestión precisa de recetas en los mezcladores.
- Impacto de Interrupción: Si SAP cae, no se pueden recibir camiones (bloqueo de muelles). Si Rockwell Batch cae, no se puede mezclar la masa automáticamente. La mezcla manual es imposible debido a los estrictos estándares de calidad y volumen de Oreo.

3.1.2 Producción y Manufactura Automatizada

El núcleo del negocio. Hornos de túnel de cientos de metros, sistemas de enfriamiento y robots de ensamblaje (sándwich).

Sistemas: PLCs Allen-Bradley ControlLogix, Variadores Kinetix (Motion Control), HMIs PanelView, Red EtherNet/IP.

Impacto de Interrupción: Detención inmediata. Si los hornos se detienen con producto adentro sin control, se produce riesgo de incendio y pérdida total del lote. La inercia térmica requiere control constante. La pérdida de sincronización en los robots de ensamblaje resulta en producto dañado y desperdicio masivo.

3.1.3 Logística, Distribución y Ventas

Mover el producto terminado a los centros de distribución y facturar a los minoristas.

Sistemas: SAP EWM (Extended Warehouse Management), SAP SD (Sales and Distribution), EDI (Intercambio Electrónico de Datos).

Impacto de Interrupción: Acumulación de stock en planta (bloqueo de salida). Incapacidad de generar guías de remisión legales. Pérdida de ventas por falta de stock en anaquel y multas contractuales por incumplimiento de entregas a clientes como Walmart o Tesco.

3.2 Evaluación de Consecuencias

El BIA evaluamos el impacto en tres dimensiones que son: Confidencialidad, Integridad y Disponibilidad (FIPS 199). Para nuestro caso Oreo, la Disponibilidad e Integridad son los factores dominantes.

Impacto Económico: Para el BIA se establece una estimación interna del costo de inactividad basada en pérdida de producción, desperdicio de materia prima, penalizaciones logísticas, horas hombre ociosas y costos de recuperación técnica. Dado que no se dispone de cifras públicas verificables para este caso, se expresan

los impactos en términos relativos (alto/medio/bajo) y se justifica la prioridad por criticidad operativa

Los datos públicos del incidente de 2017, donde una interrupción de varios días costó $100 millones, podemos estimar el costo del tiempo de inactividad .

- Mondelēz opera continuamente. $100M por 4 días de impacto severo estimado $25 millones por día globalmente.
- Para la unidad de negocio Oreo, esto se traduce en pérdidas de ingresos directos, costos de mano de obra ociosa, desperdicio de materias primas perecederas y costos de recuperación de sistemas.
- Estimación: $1 millón de dólares por hora de inactividad global de la plataforma SAP.

Impacto Operativo: La "fábrica digital" depende de datos en tiempo real. Sin la telemetría de los sensores IoT que alimentan los algoritmos de mantenimiento predictivo en la nube de AWS, las máquinas operan a "ciegas", aumentando el riesgo de fallas mecánicas catastróficas.La pérdida de trazabilidad en SAP Quality Management obligaría a destruir lotes enteros por no poder certificar la seguridad alimentaria lo cual es un altoriesgo.

Impacto Reputacional y Legal: El incumplimiento de pedidos afecta la relación con los distribuidores. Más crítico aún es el riesgo de integridad de datos: si un ciberataque altera las recetas en el sistema SCADA (ej. cambiando cantidades de alérgenos sin aviso), las consecuencias para la salud pública y las demandas legales resultantes serían devastadoras para la marca.

3.3 Definición de Objetivos de Recuperación (RTO y RPO)

Basado en el análisis de impacto, definimos los tiempos objetivo que guiarán la selección de tecnología de recuperación

Sistema Crítico	**Descripción**	**RTO (Tiempo**	**RPO (Punto**	**Justificación**

		Objetivo de Recuperación)	**Objetivo de Recuperación)**	
SAP S/4HANA (Core)	ERP Central (Finanzas, Pedidos)	4 Horas	15 minutos	Crítico para la logística global. Un RTO de 4h garantiza la continuidad del flujo logístico global y evita paros en la cadena de suministro que excedan los $4M en pérdidas. Un RPO de 15m minimiza la re-digitación de pedidos financieros complejos.
Rockwell SCADA / PLCs	Control de Planta	< 1 Hora	0 minutos (Tiempo Real)	La producción no puede detenerse. Los controladores deben ser redundantes localmente. La pérdida de datos de configuración de PLC es inaceptable.
Sistemas de Ejecución de Manufactura (MES)	Interfaz entre ERP y Planta	2 horas	1 hora	Permite un breve periodo de operación en "modo papel" o buffer local antes de saturar la línea.
Infraestructura de Red (LAN/WAN)	Conectividad	1 hora	N/A	Sin red, no hay acceso a SAP ni control remoto de planta.
Correo Electrónico / Colaboración	Comunicación	24 horas	1 horas	Importante, pero existen canales alternativos (teléfono) para la gestión inmediata de la crisis.

4. Estrategias de Recuperación y Controles Preventivos

NIST SP 800-34 dicta que las estrategias de recuperación deben ser seleccionadas para cumplir con los requisitos de RTO/RPO derivados del BIA, equilibrando el

costo y la complejidad. Además, se priorizan los controles preventivos para mitigar el riesgo antes de que ocurra el desastre

4.1 Controles Preventivos y Ciber-Resiliencia

4.1.1 Segmentación de Red Industrial (Arquitectura Purdue/IDMZ)

Para proteger los sistemas de control de planta (OT) de infecciones provenientes de la red corporativa (IT) o internet, implementamos una Zona Desmilitarizada Industrial (IDMZ) estricta según el estándar ISA/IEC 62443.

- Mecanismo: Ningún tráfico fluye directamente entre el ERP (Nivel 4) y los PLCs (Nivel 1-2). Todo intercambio de datos pasa por servidores "proxy" o "jump hosts" en la DMZ (Nivel 3.5).
- Beneficio: Si SAP o el correo corporativo son comprometidos por ransomware, el malware no puede propagarse automáticamente a los controladores de los hornos, preservando la seguridad física de la planta y permitiendo una operación en "modo isla".

4.1.2 Inmutabilidad de Respaldos

El ransomware moderno ataca primero los backups. Para contrarrestarlo, utilizamos la funcionalidad Object Lock de AWS S3 para los respaldos de bases de datos SAP y configuraciones de planta.

- Mecanismo: Los datos escritos en estos "buckets" de almacenamiento no pueden ser modificados ni eliminados por nadie, ni siquiera por el administrador "root" de la cuenta de AWS, durante un periodo de retención definido (ej. 30 días).
- Beneficio: Garantiza que siempre exista una "copia dorada" limpia de los datos para la restauración, incluso si los atacantes obtienen credenciales administrativas completas.

4.2 Estrategia de Recuperación para SAP S/4HANA (Nube AWS)

Para cumplir con un RTO de 4 horas y un RPO de 15 minutos en un entorno global, la estrategia de "Cintas de Respaldo" es obsoleta. Se selecciona una estrategia de "Warm Standby" (Espera Tibia) con Replicación Transregional.

Arquitectura:

- Región Primaria (Activa): AWS US-East (N. Virginia). Ejecuta la carga de trabajo completa.
- Región de Recuperación (Pasiva): AWS US-West (Oregón). Mantiene una infraestructura mínima.

Componentes

- Base de Datos (HANA): Se utiliza SAP HANA System Replication (HSR) en modo asíncrono. La base de datos en el sitio de recuperación está encendida pero en modo "standby", recibiendo logs continuamente. Esto cumple el RPO de <15 min (dependiendo de la latencia de red).
- Aplicación (NetWeaver): Se utiliza el patrón "Pilot Light". Los servidores de aplicación no están ejecutándose (ahorrando costos), pero sus imágenes (AMIs) están pre-configuradas y listas para ser desplegadas automáticamente mediante scripts de Infraestructura como Código (Terraform/CloudFormation) en caso de failover. Esto cumple el RTO de 4 horas (tiempo de arranque y escalado).

4.3 Estrategia de Recuperación para Sistemas Industriales (OT/Rockwell)

Los sistemas de planta requieren una estrategia diferente debido a su naturaleza física y restricciones de latencia.

Redundancia Local (Alta Disponibilidad): Los controladores críticos (PLCs) de los hornos y mezcladoras operan en pares redundantes (Hot Standby). Si el procesador primario falla, el secundario asume el control en milisegundos sin detener la producción (bumpless transfer).

Recuperación ante Desastres (Cold Standby & Digital Twin):

- Software: Se utiliza FactoryTalk AssetCentre para mantener el versionado de todos los programas de lógica (.ACD). Una copia de estos archivos se replica diariamente a un repositorio seguro en la nube (AWS S3 Inmutable) y a un servidor NAS local aislado ("Air-gapped") dentro de la planta.
- Hardware: Se mantiene un inventario estratégico de repuestos (HMIs, PLCs, VFDs) en el almacén local. En caso de daño físico (incendio, agua, sobretensión), la estrategia es el reemplazo físico y la carga manual del software desde el repositorio seguro ("Bare Metal Recovery").

5. Procedimientos de Recuperación

5.1 Fase de Activación y Notificación

El plan no se activa por incidentes menores. Se requiere una declaración formal de desastre. Los criterios incluyen:

- Pérdida total de conectividad con el centro de datos primario de AWS por más de 1 hora sin pronóstico de resolución.
- Indicadores confirmados de corrupción de datos masiva o encriptación por ransomware en sistemas SAP o Rockwell.
- Daño físico severo a una planta crítica que requiere redirigir la producción y logística global.

5.1.2 Árbol de Llamadas y Escalada

- La comunicación rápida es vital. Se utiliza un sistema de notificación automatizado (ej. Everbridge) complementado con un árbol de llamadas manual para redundancia.
- Detección: El Centro de Operaciones de Seguridad (SOC) o Supervisores de Planta detectan la anomalía.
- Notificación Inicial (T+0 a T+15 min): Se notifica al Help Desk y al Gerente de Incidentes de Turno.

- Evaluación (T+15 a T+45 min): El Equipo de Evaluación de Daños (DAT) diagnostica el alcance.
- Activación del Comité (T+60 min): El Coordinador de Contingencia convoca al Comité Ejecutivo. Se presenta la recomendación de activar el DR.
- Declaración (T+90 min): El Ejecutivo Designado autoriza formalmente el "Failover". Se inician los procedimientos técnicos.

5.2 Procedimientos Técnicos de Recuperación

- Paso 1: Validación del Estado de Replicación
- Paso 2: Ejecución del Takeover de Base de Datos
- Paso 3: Despliegue de la Capa de Aplicación (Pilot Light Inflation)
- Paso 4: Redirección de DNS y Red
- Paso 5: Validación Funcional y Liberación

5.3 Procedimientos de Recuperación de Sistemas OT

- Paso 1: Aislamiento Físico y de Red
- Paso 2: Saneamiento de Estaciones de Ingeniería
- Paso 3: Restauración de Lógica de PLC (FactoryTalk)
- Paso 4: Verificación de Seguridad Física y Reinicio

5.4 Procedimientos de Retorno a la Normalidad

- El regreso al sitio primario (Virginia) una vez resuelto el problema original es una operación delicada que requiere una ventana de mantenimiento planificada.
- Resincronización Inversa: Configurar la replicación de HSR desde Oregón (ahora origen) hacia Virginia (ahora destino). Esperar a que el estado sea SYNC.
- Parada Planificada: Detener operaciones en Oregón.
- Takeover en Origen: Ejecutar takeover en Virginia.
- Redirección DNS: Apuntar DNS de nuevo a Virginia.

- Validación: Confirmar integridad de datos transaccionales generados durante la contingencia.

6. Pruebas, Mantenimiento y Mejora Continua

Un plan de recuperación no probado es, en el mejor de los casos, una hipótesis, y en el peor, una ilusión peligrosa. NIST SP 800-34 y SP 800-84 exigen un programa riguroso de Test, Training, and Exercise (TT&E)

6.1 Esquema de Pruebas Simuladas

Para garantizar la preparación sin interrumpir la producción constante de Oreo, implementamos un enfoque escalonado:

6.1.1 Ejercicios de Escritorio - Trimestral

- Alcance: Reunión del Comité de Contingencia y líderes clave.
- Metodología: Se presenta un escenario hipotético basado en amenazas reales
- Objetivo: Validar la toma de decisiones, las líneas de comunicación y la claridad de roles. No se tocan sistemas reales. Se refinan los protocolos de notificación y escalada.

6.1.2 Pruebas Funcionales - Semestral

- Alcance: Equipos técnicos de TI y OT.
- Metodología: Recuperación de componentes específicos en entornos de prueba aislados ("Sandbox").
- Objetivo: Validar la integridad técnica de los backups y la viabilidad de los procedimientos de restauración

6.1.3 Simulacro de Escala Completa - Anual

- Alcance: Toda la organización de TI y representantes de negocio.

- Metodología: Simulación de failover de sistemas críticos. Para SAP, esto implica conmutar realmente la operación a la región de contingencia durante un fin de semana de baja actividad o ventana de mantenimiento extendida.
- Objetivo: Verificar el RTO/RPO en condiciones casi reales. Evaluar el desempeño del personal bajo estrés y la coordinación con proveedores externos (AWS, SAP Support).

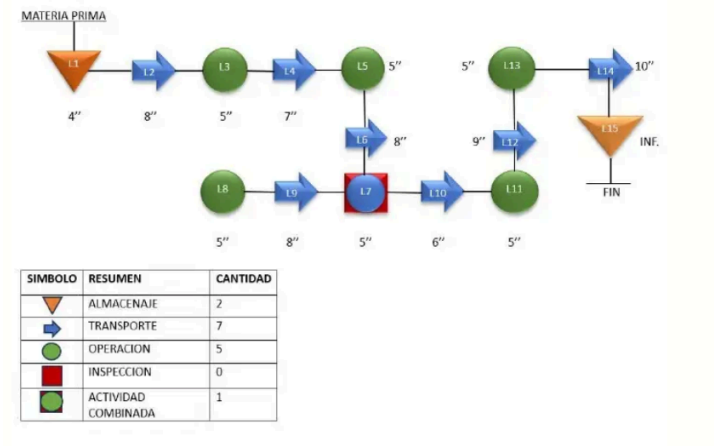
6.2 Mantenimiento del Plan y Gestión de Cambios

La infraestructura de TI de Mondelēz es dinámica. Un plan estático se vuelve obsoleto en meses.

- Integración con Gestión de Cambios: Cualquier cambio significativo en la arquitectura (ej. actualización de versión de SAP S/4HANA, instalación de nuevos robots en planta) debe disparar una revisión obligatoria del ISCP. El "Impacto en DR" es un campo obligatorio en el formulario de solicitud de cambios (RFC).
- Revisión Anual: Independientemente de los cambios, el plan debe ser auditado y actualizado anualmente para reflejar cambios en el personal (actualización de números de contacto), proveedores o estrategias de negocio.
- Lecciones Aprendidas: Tras cada prueba o incidente real, se debe realizar una sesión de "Post-Mortem" o "After Action Review". Las deficiencias identificadas se documentan en un Plan de Acción y Mejoras (POA&M) para corregir el plan.

Anexos

Diagrama de Flujo del Proceso Crítico Simulación



1.diagramas de simulación para identificar los puntos críticos de fallo

Nodo	Etapa del Proceso	Sistema TI/OT	Riesgo en DRP
Triángulo	Recepción y Almacenaje	SAP EWM / Básculas	Si SAP cae, no se puede ingresar materia prima
Flechas	Transporte a Línea	AGVs / Bandas	Fallo en red Wi-Fi industrial detiene el transporte automatizado
Círculo Verde	Mezclado	Rockwell Batch	Pérdida de receta exacta afecta sabor y textura
Cuadrado	Inspección	Sensores IoT	Punto Crítico de Control (CCP). Fallo aquí obliga a detener por riesgo de seguridad alimentaria
L11 - L13	Enfriamiento	Servos Kinetix	Sincronización milimétrica para unir las dos tapas con la crema.
L15 (Triángulo)	Almacén Producion	SAP WM	Cuello de botella logístico si no se pueden generar etiquetas de envío.

3. Diseñar de manera integral un Plan de Recuperación de Desastres (DRP) para la infraestructura de TI de una organización real, aplicando los contenidos desarrollados en el Tema 12. En esta actividad deberán asumir el rol de un equipo de planificación de continuidad del negocio y definirán el proyecto y las políticas que regirán el diseño del plan, identificar y priorizar los servicios tecnológicos críticos y la infraestructura que los soporta, analizar los principales riesgos y amenazas, establecer estrategias de recuperación adecuadas para cada servicio, y proponer un plan de respuesta a incidentes, pruebas y mantenimiento del DRP, todo ello alineado con buenas prácticas y estándares como ISO 22301 y NIST SP 800-34: el resultado será un documento técnico estructurado que evidencie el dominio conceptual, la capacidad de análisis y la aplicación práctica de los conocimientos.

PLAN DE RECUPERACIÓN DE DESASTRES (DRP) Empresa Oreo

Introducción

OREO es una de las marcas más emblemáticas a nivel mundial en la industria alimentaria y forma parte del grupo multinacional Mondelez International, que opera en muchos países y maneja complejas cadenas de producción y distribución, dada la gran dependencia de sistemas tecnológicos para la fabricación, control de calidad, logística, ventas y gestión administrativa, la continuidad de las operaciones de TI es crucial para la sostenibilidad del negocio.

El Plan de Recuperación de Desastres DRP se presenta como una herramienta estratégica que permite a OREO responder de manera organizada y eficiente ante eventos disruptivos que puedan afectar su infraestructura tecnológica, minimizando así el impacto en el

negocio, además debe ser probado de manera regular y alinearse con estándares internacionales como ISO 22301 y NIST SP 800-34, que ofrecen directrices para la planificación, implementación y mejora continua de los planes de recuperación.

Objetivo General del proyecto

Desarrollar un Plan de Recuperación de Desastres para la infraestructura de Tecnologías de la Información de la empresa OREO, con la finalidad de brindar continuidad operativa , integridad y disponibilidad de los procesos críticos, y la protección de la información ante situaciones de emergencia o desastre.

.

Importancia del DRP en la Industria Alimentaria

La industria alimentaria enfrenta un alto nivel de criticidad debido a las estrictas regulaciones sanitarias, la necesidad de trazabilidad y las expectativas de los consumidores. Cualquier interrupción tecnológica puede poner en riesgo la seguridad alimentaria y acarrear sanciones legales. Por eso, el DRP de OREO juega un papel fundamental en la protección de la calidad del producto, la confianza del consumidor y la reputación de la marca.

Infraestructura Tecnológica de Soporte de la Empresa OREO

La infraestructura tecnológica que respalda a la empresa OREO es fundamental para el desarrollo y mantenimiento de sus operaciones globales en producción, logística, comercialización y gestión administrativa. Como parte de Mondelez International, OREO se mueve en un entorno altamente digitalizado que demanda sistemas tecnológicos sólidos, escalables y resilientes para asegurar la continuidad del negocio.

Componente	Descripción	Función dentro del DRP
Centros de Datos	OREO utiliza infraestructura híbrida: Región Primaria AWS US-East y Región de Recuperación US-West con replicación de datos asíncrona, climatización controlada, protección contra incendios y monitoreo continuo.	Permiten la continuidad de los servicios críticos y la recuperación desde un sitio alterno en caso de desastre.
Servidores	Servidores de aplicación SAP NetWeaver desplegados mediante AMIs preconfiguradas en AWS y virtualizados que soportan aplicaciones industriales y corporativas. La virtualización optimiza recursos y facilita la restauración de sistemas.	Reduce los tiempos de recuperación (RTO) y permite una rápida reinstauración de servicios críticos.
Plataformas en la Nube	Uso de infraestructura híbrida (on-premise y cloud) para aplicaciones, almacenamiento y respaldo de información.	Facilita la recuperación remota, escalabilidad y disponibilidad de los sistemas ante fallas locales.
Almacenamiento de Datos	Amazon S3 con Object Lock para inmutabilidad y volúmenes EBS replicados	Garantiza la integridad y disponibilidad de la información durante la recuperación.

Redes y Comunicaciones	Redes LAN y WAN interconectan plantas, centros logísticos y oficinas administrativas, con enlaces redundantes.	Asegura la conectividad continua entre sistemas críticos durante y después del desastre.
Aplicaciones Críticas	Sistemas ERP (SAP), gestión de producción, logística, finanzas y ventas.	Son priorizadas para recuperación inmediata por su impacto directo en el negocio.
Seguridad de la Información	Firewalls, sistemas de detección de intrusos, cifrado de datos y control de accesos.	Previene incidentes de seguridad y protege la información durante la recuperación.
Respaldos y Replicación	Copias de seguridad periódicas y replicación casi en tiempo real hacia sitios alternos.	Permite restaurar datos minimizando la pérdida de información (RPO).
Monitoreo y Gestión	Herramientas de monitoreo de infraestructura, aplicaciones y seguridad.	Facilita la detección temprana de incidentes y la activación oportuna del DRP.

Análisis de Riesgos y Amenazas

El análisis de riesgos y amenazas es fundamental para identificar eventos que podrían poner en peligro la continuidad de los servicios tecnológicos y operativos de la empresa OREO. Este análisis se fundamenta en principios de gestión del riesgo, teniendo en cuenta tanto la probabilidad de que ocurran estos eventos como su posible impacto en la organización. Su propósito es anticipar posibles desastres y establecer estrategias adecuadas para mitigar y recuperarse de ellos.

Categoría de Riesgo	**Amenaza Identificada**	**Descripción del Riesgo**	**Impacto en el Negocio**
Riesgos Tecnológicos	Fallas de hardware	Averías en servidores, equipos de red o almacenamiento que soportan sistemas críticos.	Interrupción de sistemas ERP, producción y pérdida de disponibilidad de servicios.
Riesgos Tecnológicos	Ataques cibernéticos	Malware, ransomware o accesos no autorizados a sistemas corporativos.	Pérdida de información, paralización operativa y daño reputacional.
Riesgos Tecnológicos	Fallas de software	Errores en aplicaciones o actualizaciones defectuosas.	Caída de sistemas críticos y retrasos en la operación.

Riesgos Naturales	Terremotos	Movimientos sísmicos que afectan plantas de producción y centros de datos.	Daños físicos severos e interrupción prolongada de operaciones.
Riesgos Naturales	Inundaciones	Eventos climáticos extremos que dañan instalaciones físicas.	Pérdida de infraestructura y activación del DRP.
Riesgos Naturales	Incendios	Fallas eléctricas o eventos accidentales en instalaciones.	Pérdida de equipos y riesgo para la continuidad del negocio.
Riesgos Operacionales	Error humano	Configuraciones incorrectas o malas prácticas operativas.	Interrupción de servicios y retrasos en la recuperación.
Riesgos Operacionales	Falta de capacitación	Personal sin entrenamiento adecuado en procedimientos de emergencia.	Respuesta ineficiente ante incidentes y aumento del tiempo de recuperación.
Riesgos de Seguridad Física	Acceso no autorizado	Ingreso de personas no autorizadas a áreas críticas.	Robo, sabotaje o exposición de información sensible.

Riesgos de Seguridad Física	Robo de equipos	Sustracción de servidores o dispositivos tecnológicos.	Pérdida de activos y riesgo de fuga de información.
Riesgos Regulatorios y Legales	Incumplimiento normativo	Falta de cumplimiento de normas sanitarias o de protección de datos.	Multas, sanciones legales y daño a la imagen corporativa.
Riesgos de Proveedores	Fallas de terceros	Interrupciones en servicios de nube, telecomunicaciones o soporte.	Dependencia externa que retrasa la recuperación de servicios críticos.

Análisis de Impacto al Negocio (BIA) – Empresa OREO

El Análisis de Impacto al Negocio BIA, es una herramienta clave en el Plan de Recuperación de Desastres. Su función principal es identificar los procesos críticos de una organización y evaluar cómo la interrupción de estos podría afectar las operaciones, las finanzas, el cumplimiento normativo y la reputación de la empresa. En el caso de OREO, que forma parte de Mondelez International, el BIA es especialmente importante debido a la complejidad de su operación a nivel global y su fuerte dependencia de la tecnología.

Desde un enfoque teórico, el BIA se centra en identificar los procesos esenciales, analizar los impactos que podrían surgir de su interrupción y establecer los tiempos máximos aceptables para la recuperación. Este análisis es fundamental para tomar decisiones estratégicas dentro del Plan de Recuperación de Desastres y para priorizar las acciones de recuperación.

Plan de Respuesta a Incidentes

El Plan de Respuesta a Incidentes forma parte fundamental del Plan de Recuperación de Desastres (DRP) de la empresa OREO, ya que establece las acciones iniciales que deben ejecutarse ante la ocurrencia de un evento disruptivo que afecte a la infraestructura tecnológica. Su objetivo es contener el incidente, minimizar el impacto en los servicios críticos y activar oportunamente los mecanismos de recuperación.

Activación del DRP

El DRP será activado cuando ocurra un incidente que provoque la indisponibilidad total o parcial de los servicios tecnológicos críticos, tales como fallas graves de infraestructura, ciberataques, desastres naturales o eventos que comprometan la integridad de la información.

La activación será autorizada por el Comité de Continuidad del Negocio, previa evaluación del impacto del incidente.

Roles y responsabilidades

- Comité de Continuidad del Negocio: Autoriza la activación del DRP y coordina las decisiones estratégicas.
- Equipo de TI: Ejecuta las acciones técnicas de contención, respaldo y recuperación de los sistemas.
- Responsable de Seguridad de la Información: Evalúa riesgos de seguridad y asegura la protección de los datos.
- Área de Comunicaciones: Gestiona la comunicación interna y externa durante el incidente.
- Proveedores tecnológicos: Brindan soporte especializado según los acuerdos de nivel de **servicio (SLA).**

Procedimiento de respuesta

1. Detección y notificación del incidente.

2. Evaluación del impacto en los servicios críticos.

3. Activación del DRP y del sitio alterno si aplica.

4. Contención del incidente para evitar su propagación.

5. Ejecución de las estrategias de recuperación definidas.

6. Restauración progresiva de los servicios.

7. Documentación del incidente y lecciones aprendidas.

Plan de comunicación

Durante un incidente, se mantendrán canales de comunicación claros entre el equipo de TI, la alta dirección y las áreas operativas. En caso de afectar a clientes o socios comerciales, se emitirán comunicados oficiales para mantener la transparencia y preservar la confianza en la marca OREO.

Plan de Pruebas del DRP

Las pruebas del Plan de Recuperación de Desastres son esenciales para validar su efectividad y asegurar que el personal involucrado conozca sus responsabilidades. Estas pruebas permiten identificar debilidades, mejorar los procedimientos y garantizar una respuesta adecuada ante un desastre real.

Tipos de pruebas

- Pruebas de escritorio: Revisión teórica del DRP y simulación de escenarios sin afectar los sistemas productivos.
- Pruebas parciales: Evaluación de componentes específicos, como la restauración de respaldos o la conmutación a servidores alternos.
- Pruebas completas: Simulación de un desastre real, activando el DRP y recuperando los servicios desde el sitio alterno.

Frecuencia de las pruebas

- Pruebas de escritorio: Semestrales.
- Pruebas parciales: Anuales.
- Pruebas completas: Cada año o ante cambios significativos en la infraestructura.

Objetivos de las pruebas

- Verificar el cumplimiento de los tiempos de recuperación (RTO).
- Comprobar la integridad de los respaldos (RPO).
- Evaluar la capacidad de respuesta del personal.
- Detectar oportunidades de mejora en el plan.

Mantenimiento y Mejora Continua del DRP

El Plan de Recuperación de Desastres de OREO debe mantenerse actualizado para asegurar su eficacia frente a cambios tecnológicos, organizacionales o regulatorios. El mantenimiento del DRP se realizará bajo un enfoque de mejora continua, conforme a los lineamientos de la norma ISO 22301.

Actividades de mantenimiento

- Revisión anual del DRP y actualización de la documentación.
- Actualización del plan ante cambios en la infraestructura tecnológica o en los servicios críticos.
- Revisión de los acuerdos con proveedores y servicios en la nube.
- Actualización de los datos de contacto del equipo de respuesta.

Capacitación y concienciación

El personal de TI y los miembros del Comité de Continuidad del Negocio recibirán capacitación periódica sobre los procedimientos del DRP, con el fin de asegurar una respuesta eficiente ante incidentes.

Mejora continua

Después de cada incidente o prueba del DRP, se elaborará un informe de resultados que permita identificar lecciones aprendidas y aplicar mejoras al plan, fortaleciendo así la resiliencia tecnológica y operativa de la empresa OREO.

4. Se deberá elaborar un video explicativo que desarrolle los tres literales mencionados previamente, garantizando la participación activa de todos los integrantes del grupo.
   El enlace del video deberá incorporarse en el mismo documento. Cada integrante deberá intervenir de manera visible durante la grabación.

Link de la grabacion

https://www.youtube.com/watch?v=3CacDTkOgBs

Referencias

Mondelēz International. (2017, 6 de julio). Update on Cyber-Attack and Preliminary Estimate of Financial Impacts [Comunicado de prensa]. https://ir.mondelezinternational.com/news-releases/news-release-details/update-cyber-attack-and-preliminary-estimate-financial-impacts/

Mondelēz International. (2024, 17 de diciembre). Mondelēz International Moves to Amazon Web Services to Advance its Digital Strategy [Comunicado de prensa]. https://ir.mondelezinternational.com/news-releases/news-release-details/mondelez-international-moves-amazon-web-services-advance-its

Rockwell Automation. (s.f.). Mondelēz Rolls Out Its Integrated Digital Factory. Rockwell Automation Case Studies.

https://www.rockwellautomation.com/en-gb/company/news/magazines/mondelez-rolls-out-its-integrated-digital-factory.html

Swanson, M., Bowen, P., Phillips, A. W., Gallup, D., & Lynes, D. (2010). Contingency Planning Guide for Federal Information Systems (NIST Special Publication 800-34 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-34r1

Wilkinson, L. (2024, 2 de agosto). Mondelēz launches $1.2B ERP, supply chain transformation. CIO Dive. https://www.ciodive.com/news/mondelez-erp-supply-chain-SAP-accenture-transformation/723188/